

	E0X ECU 27 服务密钥使用和管理技术要求		★机密★
编制日期：2023/7/26	编者：	版次：V1.1	页次：

E0X ECU 27 服务密钥使用和管理技术要求

拟制: _____ 日期: _____

审核: _____ 日期: _____

批准: _____ 日期: _____

	E0X ECU 27 服务密钥使用和管理技术要求		★机密★
编制日期：2023/7/26	编者：	版次：V1.1	页次：

变更记录

版本	发布日期	作者	说明
V1.0	2023/7/26	马蔚	初版
V1.1	2023/8/15	马蔚	增加密钥安全和随机数要求

	E0X ECU 27 服务密钥使用和管理技术要求		★机密★
编制日期：2023/7/26	编者：	版次：V1.1	页次：

目录

1	文档说明.....	1
2	术语.....	2
3	诊断密钥总体方案.....	2
3.1	安全等级划分.....	2
3.2	一类型一密钥.....	2
3.3	车内 27 服务方法.....	2
4	诊断设备和 ECU 初始状态.....	4
5	密钥安全要求.....	4

1 文档说明

在车辆近端维护时,诊断规范规定了高权限的近端维护操作(如数据写入、例程控制等)需做权限控制,只有当通过 27 服务的安全认证后,才能执行高权限的维护操作。本规范规定了 27 服务安全认证方法,目的是建立车辆诊断开发、设计过程中的 27 服务认证过程的安全规则。涵盖的内容包括:27 服务认证过程、秘钥的管理要求。

ONLY FOR I CAR

2 术语

术语	说明
对称算法 (Symmetric key algorithm)	对称算法采用相同的密钥执行加密或解密，如 AES 算法。
消息认证码 (Message authentication code)	密码学上的一种数据校验和，通过使用对称密钥来检测数据是否发生意外或有意的修改。消息认证码简称 MAC。
种子 (Seed)	本规范中的种子是指真/伪随机数产生器的输出。

3 诊断密钥总体方案

3.1 安全等级划分

本规范将 27 服务的认证安全等级划分为 3 级，各安全等级之间安全强度一致，为了便于不同操作的授权管理，本规范将安全等级划分为：1 级、2 级、3 级。其中各级安全算法在传输中的字段定义以诊断规范为准。

各安全级之间使用的安全算法相同，但密钥不同。其中 1 级和 3 级安全认证应支持，2 级安全认证预留。

SID (hex)	Service Name	CVT	Application			Bootloader			Addressing mode		Security Access	SPRMID
			Default session	Programming session ¹	Extended session	Default session	Programming session	Extended session	Physical addressing	Functional addressing		
27	SecurityAccess 安全访问	0x00 (Reserved by ISO)	M	/	✓	✓	/	✓	/	✓	/	/
		0x01 requestSeed to reach security level: Unlocked (Level 1)	M	/	✓	✓	/	✓	-	✓	/	/
		0x02 sendKey to reach security level: Unlocked (Level 1)	M	/	✓	✓	/	✓	-	✓	/	/
		0x03 requestSeed to reach security level: Unlocked (Level 2)	M	/	✓	✓	/	✓	-	✓	/	/
		0x04 sendKey to reach security level: Unlocked (Level 2)	M	/	✓	✓	/	✓	-	✓	/	/
		0x11 requestSeed to reach security level: Unlocked (Level 3)	M	/	✓	✓	/	✓	-	✓	/	/
		0x12 sendKey to reach security level: Unlocked (Level 3)	M	/	✓	✓	/	✓	-	✓	/	/

3.2 一类型一密钥

一类一密钥(固定秘钥)。

3.3 车内 27 服务方法

(1) 在 27 服务的第 (2) 步中生成的挑战值为长度 16Byte 的随机数；

对 27 服务安全认证过程使用的随机数优先推荐采用 TRNG 产生，若无条件采用 TRNG

的控制器可以采用密码学安全的 PRNG 产生。

(2) 在 27 服务的第(4)步中客户端基于预共享密钥对挑战值的加密运算算法采用 AES-CMAC，密钥长度 128bit，数据填充方式参看 AES-CMAC 算法，算法详细实现过程可参看 RFC4493；

(3) 在 27 服务的第(6)步中服务端基于预共享密钥对挑战值 AES-CMAC 计算 CMAC，并将客户端发送的身份凭证与计算的 CMAC 进行对比，若一致，则鉴权通过，若不一致，则鉴权失败。

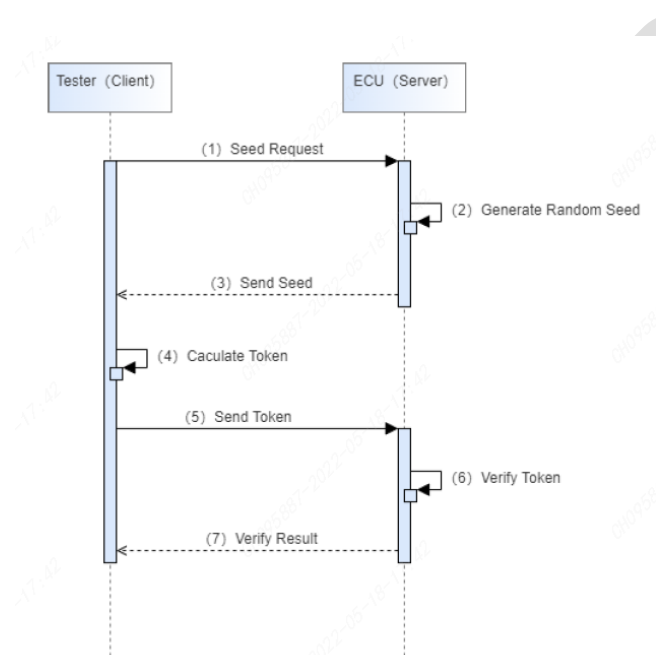


图 1 UDS 27 访问流程

上图中的 27 服务认证是基于预共享密钥的单向挑战应答鉴权过程。其中，

第（1）步：客户端发起认证请求；Seed Request: 27 XX¹，XX¹为安全等级字段；

第（2）步：服务端生成挑战值；

第（3）步：服务端反馈挑战值；Send Seed: 67 XX¹ XX XX²，XX XX²为安全随机数；

第（4）步：客户端基于与共享密钥对挑战值进行加密运算，并将加密密文作为身份凭证；Calculate Token: Token=AES128-CMAC (Key, Seed)；

第（5）步：客户端向服务端反馈身份凭证；Send Token: 27 XX³Token，XX³为反馈级安全算法字段来表征；

第（6）步：服务端对客户端的身份进行鉴权；Verify Token: Token'=AES-CMAC (Key, Seed)；

第（7）步：服务端将认证结果消息反馈给客户端。VerifyResult: 67 XX³。

举例 1:

Seed: 66B0CF31F56AC16ABF4610DF87A1AE20

Key（密钥）: 3D2E6DE2A12517BAC5B31BBD0E7E3B54

Token: 0D4DE052272CC4F56E2A4FBC8DCFA931

security level: 01/02

Tx: 27 01

Rx: 67 01 66 B0 CF 31 F5 6A C1 6A BF 46 10 DF 87 A1 AE 20

Tx: 27 02 0D 4D E0 52 27 2C C4 F5 6E 2A 4F BC 8D CF A9 31

Rx: 67 02

举例 2:

Seed: F0B6E53EA901FD31E66481D423987CC7

Key（密钥）: D0DFAA1588E04B5B14CE834E65E621CD

Token: A0AAC6C78776823D53C9317E12C7B6F4

security level: 11/12

Tx: 27 11

Rx: 67 11 F0 B6 E5 3E A9 01 FD 31 E6 64 81 D4 23 98 7C C7

Tx: 27 12 A0 AA C6 C7 87 76 82 3D 53 C9 31 7E 12 C7 B6 F4

Rx: 67 12

4 诊断设备和 ECU 初始状态

诊断设备及 ECU 需离线预置密钥。

5 密钥安全要求

- 1) 奇瑞产生并保管对称密钥SecKey，密钥应该安全存储；
- 2) 如果ECU具备安全硬件存储能力，密钥应该存储在独立的SE芯片或者HSM安全模块中。不具备安全硬件存储能力的，应该保存在非易失性存储空间，使用混淆等方法避免密钥的明文存储，并对其完整性进行检查（使用SHA256或SHA512），对称密钥不能读出/导出到设备以外；
- 3) 对称密钥SecKey，可以在ECU出厂阶段预制在ECU中，需要保证密钥分发、灌入过

程中的保密性和完整性，不能有人可以读出对称密钥；

- 4) 生成的对称密钥SecKey长度要求为128Bit。

6 随机数要求

27 服务中使用的随机数，如果有加密模块，需要使用密码学上的真随机数，如果没有加密模块，需要使用可信的伪随机数生成器，例如 CTR_DRBG，HASH-DRBG，并保证产生随机数不可重复。